



Projet 2: Sécurisation accès distant par VPN

24/11/2025

Sébastien GUERRERO

Table des matières

Section 1 – Introduction générale.....	3
Section 2 – Analyse et compréhension du besoin.....	4
2.1. Contexte initial et état des lieux.....	4
2.2. Problématiques et risques identifiés	5
2.3. Objectifs du projet	6
Section 3 – Conception et planification de l’architecture	7
3.1. Choix de l’architecture cible.....	7
3.2. Définition des zones réseau et de leur rôle.....	10
3.3. Plan d’adressage IP.....	11
3.4. Stratégie d’authentification et de gestion des droits	12
3.5. Schéma physique et logique de la solution VPN.....	13
3.6. Résumé des choix techniques.....	14
3.7. Conclusion sur la conception.....	15
Section 4 – Mise en œuvre et configuration des services	16
4.1. Mise en œuvre réseau — pfSense, routage et filtrage	16
4.2. Configuration des services Windows (AD / DNS / LDAPS).....	17
4.3. Passerelle VPN — Installation et configuration OpenVPN	22
4.4. Postes clients — Configuration et tests de connexion	28
4.5. Durcissement et mesures de sécurité appliquées.....	32
4.5.1. Durcissement de pfSense et d’OpenVPN	32
4.6. Journalisation, supervision et exploitation	32
Section 5 – Bilan et conclusion	34
5.1. Bilan technique	34
5.4. Axes d’amélioration et perspectives	35
Références normatives et guides.....	37
Table des abréviations	37

Section 1 – Introduction générale

Dans sa configuration actuelle, l'entreprise dispose d'un système d'information centralisé autour d'un réseau local (LAN) sur lequel sont connectés l'ensemble des postes de travail des salariés. Un serveur Windows joue un rôle clé : il héberge les comptes utilisateurs, gère l'authentification et centralise les données via un serveur de fichiers. Les droits d'accès aux différents dossiers sont administrés au moyen de groupes et d'ACL, ce qui permet à chaque collaborateur de ne voir et de modifier que les documents qui lui sont autorisés.

Jusqu'à présent, l'utilisation de ces ressources est strictement réservée aux postes physiquement présents sur le site de l'entreprise. Autrement dit, un salarié doit être connecté au réseau interne pour accéder au serveur de fichiers et aux documents nécessaires à son activité. Cette organisation limite fortement la mobilité et complique le recours au télétravail, aux interventions à distance ou aux astreintes.

Face à l'évolution des usages (travail à domicile, déplacements fréquents, besoin d'accès en dehors des horaires classiques), la direction a formulé une demande explicite : mettre en place une solution d'accès distant sécurisé permettant aux employés autorisés d'accéder au serveur de fichiers de l'entreprise comme s'ils étaient sur site, tout en conservant le même niveau de sécurité et les mêmes règles de droits que lors d'une connexion locale.

Pour répondre à ce besoin, l'entreprise souhaite déployer une solution de VPN (Virtual Private Network). Le VPN doit créer un tunnel chiffré entre le poste distant de l'utilisateur et le réseau interne de l'entreprise, de manière à ce que les flux traversant internet soient protégés en confidentialité et en intégrité. Une fois connecté au VPN, l'utilisateur doit retrouver son environnement habituel : authentification avec son compte existant et accès aux partages de fichiers qui lui sont attribués.

Ce projet s'inscrit dans une démarche de sécurisation globale du SI, en s'appuyant sur :

- Les recommandations de l'ANSSI concernant la sécurisation des accès distants et l'utilisation de VPN ;
- Les référentiels de menaces tels que MITRE ATT&CK, pour identifier les modes opératoires d'attaque liés aux accès externes (vol de comptes, exploitation de services exposés, déplacement latéral, etc.) ;
- Les exigences de la RGPD, en particulier sur la protection des données à caractère personnel transitant via le VPN et sur la gestion des journaux de connexion.

Le présent document a donc pour objectif de décrire et justifier la mise en place d'une solution VPN adaptée au contexte de l'entreprise : analyse du besoin, conception de l'architecture cible, mise en œuvre technique, mesures de sécurité associées, puis bilan et perspectives.

Section 2 – Analyse et compréhension du besoin

2.1. Contexte initial et état des lieux

L'entreprise possède un réseau local unique sur lequel sont raccordés ses postes utilisateurs et ses serveurs. Le cœur de l'infrastructure repose sur :

- Deux serveur Windows (contrôleur de domaine / serveur de fichiers) gérant les comptes utilisateurs et les partages réseau ;
- Des postes clients intégrés au domaine, utilisés sur le site de l'entreprise ;
- Un accès Internet protégé par un équipement de sécurité (pare-feu), qui filtre les flux entrants et sortants.

Les utilisateurs se connectent à leur session Windows au moyen d'un identifiant et d'un mot de passe gérés par l'annuaire Active Directory. Une fois authentifiés, ils accèdent au serveur de fichiers, sur lequel les droits ont été paramétrés pour refléter l'organisation interne (services, équipes, niveaux hiérarchiques, etc.). Cette gestion centralisée permet déjà de respecter le principe de moindre privilège : chaque utilisateur ne dispose que des droits nécessaires à son travail.

Actuellement, les accès sont exclusivement locaux :

- Le serveur de fichiers n'est pas exposé directement sur Internet ; aucun mécanisme officiel d'accès distant n'est en place (pas de VPN, pas de portail d'accès sécurisé) ;
- Les éventuelles connexions à distance se limitent à des solutions ponctuelles ou non maîtrisées, qui ne répondent pas aux exigences de sécurité formalisées par l'entreprise.

Dans ce contexte, plusieurs demandes émanent de la direction et des utilisateurs :

- Permettre à certains salariés de travailler à distance (télétravail régulier ou occasionnel) tout en accédant aux mêmes données que sur site ;
- Autoriser des interventions hors site (par exemple pour la maintenance, l'astreinte ou les déplacements commerciaux) sans avoir à recourir à des pratiques risquées (copies locales massives, envoi de documents par email, etc.) ;
- Conserver un fonctionnement transparent pour les utilisateurs : même compte, mêmes dossiers, même logique d'accès, que la connexion soit locale ou distante.

2.2. Problématiques et risques identifiés

L'absence de solution d'accès distant structurée pose plusieurs problématiques majeures, tant en termes de fonctionnement que de sécurité.

Sur le plan opérationnel :

- Les collaborateurs ne peuvent pas accéder au serveur de fichiers lorsqu'ils sont en déplacement ou en télétravail ;
- Certains utilisateurs contournent cette contrainte en recourant à des solutions non contrôlées (envoi de fichiers par email personnel, utilisation de services de stockage en ligne grand public, copies sur supports amovibles), ce qui échappe à toute maîtrise de la DSI.

Sur le plan de la sécurité et de la conformité, les risques sont importants :

- **Exposition non maîtrisée de services** : pour répondre rapidement à un besoin, un service pourrait être exposé directement sur Internet (ex : RDP, partage SMB, accès web à un répertoire), ouvrant la porte à des attaques classiques (scan, brute force, exploitation de vulnérabilités).
- **Compromission de comptes utilisateurs** : en l'absence de mécanismes d'authentification renforcée et de surveillance des connexions à distance, un attaquant ayant récupéré des identifiants pourrait se connecter comme un utilisateur légitime et accéder aux fichiers.
- **Mouvement latéral au sein du SI** : une fois à l'intérieur du réseau (via un compte compromis ou un service mal protégé), un attaquant pourrait tenter de se déplacer vers d'autres serveurs ou postes pour étendre son contrôle et exfiltrer davantage de données.
- **Atteinte à la confidentialité des données** : le serveur de fichiers contient des documents susceptibles d'intégrer des données personnelles (RH, clients, partenaires) et des informations confidentielles pour l'entreprise. Une exfiltration ou une compromission de ces données pourrait entraîner :
- **Une violation de la RGPD** (article 32 sur la sécurité des traitements) ;

Enfin, l'absence de solution centralisée d'accès distant empêche la mise en place d'une journalisation cohérente des connexions extérieures. Sans VPN et sans politique de logs, il est difficile voire impossible de :

- Retracer qui s'est connecté, quand et depuis où ;
- Détecter des comportements anormaux (multiples tentatives échouées, connexions depuis des pays inhabituels, horaires atypiques) ;
- Constituer des preuves en cas d'incident de sécurité.

L'ensemble de ces éléments montre que la situation actuelle n'est pas alignée avec les bonnes pratiques de l'ANSSI ni avec les exigences de la RGPD en matière de protection des données et de maîtrise des accès.

2.3. Objectifs du projet

Pour répondre aux besoins exprimés par la direction tout en maîtrisant les risques identifiés, le projet de sécurisation des accès distants par VPN poursuit les objectifs suivants :

1. Fournir un accès distant sécurisé au serveur de fichiers

Mettre en place une solution VPN permettant aux utilisateurs autorisés de se connecter depuis l'extérieur au réseau de l'entreprise, de manière à accéder au serveur de fichiers comme s'ils étaient connectés localement.

2. Garantir un niveau de sécurité élevé des communications

Assurer la confidentialité et l'intégrité des données échangées via un tunnel chiffré, reposant sur des protocoles et algorithmes conformes aux recommandations de l'ANSSI (versions de TLS/IPsec, suites cryptographiques robustes, etc.).

3. S'appuyer sur l'infrastructure d'authentification existante

Utiliser les comptes Windows / Active Directory déjà en place pour authentifier les utilisateurs du VPN, afin de conserver une gestion centralisée des identités et des droits. Idéalement, seuls certains groupes AD seront autorisés à utiliser le VPN (principe de moindre privilège).

4. Préserver la cohérence des droits d'accès

Faire en sorte que, une fois connecté au VPN, l'utilisateur se retrouve dans une situation équivalente à celle d'une connexion locale : mêmes partages, mêmes ACL, mêmes restrictions. Le VPN doit être un pont sécurisé vers le réseau interne, pas une voie parallèle avec des règles différentes.

5. Renforcer la traçabilité et la supervision des accès distants

Mettre en place une journalisation des connexions VPN (succès, échecs, durée, adresse IP d'origine, utilisateur) afin de pouvoir :

- Analyser les usages,
- Détecter les anomalies ou tentatives d'attaques,
- Disposer de traces en cas d'incident de sécurité.

Le tout en respectant les principes de la RGPD sur la minimisation et la durée de conservation des données de journalisation.

6. Aligner la solution avec les référentiels ANSSI / MITRE / RGPD

Concevoir la solution de manière à :

- Réduire l'exposition aux techniques d'attaque décrites dans MITRE ATT&CK (en durcissant le service VPN, en limitant les mouvements latéraux, etc.) ;
- Appliquer les recommandations ANSSI en matière d'hygiène informatique, de segmentation et de sécurisation des accès distants ;
- Respecter les obligations de la RGPD concernant la sécurité des données et la protection de la vie privée des personnes concernées.

Section 3 – Conception et planification de l'architecture

3.1. Choix de l'architecture cible

3.1.1. Comparaison avec d'autres solutions et architecture générale retenue

Comparaison avec des solutions commerciales (Fortinet, Sophos, etc.)

Sur le marché, des solutions comme Fortinet FortiGate ou Sophos Firewall/XG proposent des appliances matérielles ou virtuelles « tout-en-un » (firewall, VPN, IPS, filtrage web, sandboxing...). Elles offrent :

- Des interfaces très intégrées, adaptées aux grandes infrastructures ;
- Un support éditeur et des services de maintenance ;
- Des fonctionnalités avancées (SD-WAN, filtrage applicatif poussé, sécurité mail, etc.).

En contrepartie :

- Elles nécessitent des licences payantes (matériel + souscriptions annuelles) qui peuvent être difficilement justifiables pour une PME ou un contexte pédagogique ;
- Certaines fonctionnalités sont verrouillées derrière des packs payants ;
- La complexité globale peut être surdimensionnée pour un environnement relativement simple (un seul site, un seul VPN nomade).

À l'inverse, pfSense (édité par Netgate) est une solution open source de firewall/router, très utilisée en PME, labo et environnements académiques, qui offre :

- L'absence de coûts de licence : les fonctionnalités firewall/VPN sont incluses ;
- Une grande flexibilité de configuration (VLAN, routage, VPN IPsec/SSL, portail captif, etc.) ;
- Une communauté importante et une documentation abondante.

Ses principaux inconvénients, comparés à Fortinet/Sophos, sont :

- L'absence de support constructeur "clé en main" par défaut (sauf contrat spécifique Netgate) ;
- Une courbe d'apprentissage parfois plus technique ;
- La nécessité de gérer soi-même l'OS (sauvegardes de config, mises à jour, etc.).

Dans le cadre de ce projet :

- Le choix de pfSense permet de maîtriser le coût, d'avoir un environnement très pédagogique, et de mettre l'accent sur les principes d'architecture et de sécurité plutôt que sur le paramétrage propre à une marque ;
- La possibilité de combiner pare-feu + VPN sur un même équipement virtuel simplifie la maquette tout en restant réaliste pour une PME.

3.1.2. Type de VPN : OpenVPN sur pfSense vs IPsec / WireGuard / appliances

Le projet retient un VPN SSL basé sur OpenVPN, intégré nativement à pfSense.

Avantages d'OpenVPN dans ce contexte :

- Protocole éprouvé, largement documenté, multi-plateforme (clients disponibles sur Windows, Linux, mac OS, mobiles, etc.)
- Excellente stabilité et comportement robuste sur des réseaux instables ;
- Grande souplesse de configuration (authentification par certificats, intégration avec LDAP/AD, choix fins des suites cryptographiques) ;
- Intégration directe dans pfSense, ce qui simplifie la mise en œuvre.

Comparaison avec IPsec (IKEv2) :

- IPsec IKEv2 est souvent recommandé par les guides de sécurité (dont ANSSI) pour des scénarios site-à-site ou nomades, avec de très bonnes performances et un support natif dans les OS récents
- Toutefois, sa configuration est généralement plus complexe (politiques, phases 1 et 2, paramètres asymétriques, etc.), et le débogage peut être moins intuitif qu'OpenVPN sur un seul équipement ;

Comparaison avec WireGuard :

- WireGuard est un protocole plus récent, très léger (quelques milliers de lignes de code vs des centaines de milliers pour OpenVPN), conçu pour être très performant et simple à configurer ;
- En pratique, il offre souvent de meilleurs débits et une latence plus faible que OpenVPN ou IPsec, avec une cryptographie moderne ;
- En revanche, dans un contexte d'entreprise « classique », OpenVPN reste encore plus répandu et mieux supporté/documenté dans de nombreuses solutions existantes (outils, tutos, intégrations), ce qui est un avantage pédagogique important.

Comparaison avec les VPN intégrés Fortinet / Sophos :

- Fortinet et Sophos proposent leurs propres clients VPN propriétaires (SSL VPN, IPsec) étroitement intégrés à leurs appliances ;
- Ces solutions sont très pratiques dans des environnements homogènes 100 % Fortinet ou 100 % Sophos, mais elles enferment l'entreprise dans un écosystème propriétaire, avec des contraintes de licence et de versions

Conclusion pour le projet :

Compte tenu du contexte (un seul site, environ 50 utilisateurs, budget limité), le duo pfSense + OpenVPN offre le meilleur compromis :

- Sécurité élevée (TLS, certificats, suites modernes) ;
- Mise en œuvre maîtrisable sur un unique équipement virtuel ;
- Coût nul en licences ;
- Documentation et communauté abondantes.

L'architecture cible reposera donc sur un pare-feu unique pfSense, jouant à la fois le rôle de passerelle Internet et de serveur VPN. Pfsense est déployé en machine virtuelle, avec :

- Une interface WAN raccordée au réseau externe, en 172.16.9.230 ;
- Une interface LAN en 192.168.1.1, passerelle du réseau interne 192.168.1.0/24.

Tout le trafic, y compris les connexions VPN, transite par ce pfSense, ce qui centralise le contrôle des flux et simplifie l'exploitation.

3.1.3. Mode d'accès et type de tunnel

Le VPN est un VPN nomade (remote access), destiné aux salariés (utilisateurs classiques et administrateurs).

Il y a deux types de tunnel :

- Le full tunnel :
 - Renforce la sécurité (tout le trafic passe par les contrôles du pare-feu de l'entreprise) ;
 - Simplifie la politique de filtrage (une seule sortie Internet maîtrisée) ;
 - Alourdit légèrement la consommation de bande passante côté entreprise ;
- Le split tunnel :
 - Réduit la charge sur le lien WAN de l'entreprise ;
 - Mais laisse le poste utilisateur simultanément connecté au LAN distant et au réseau local non maîtrisé (box perso), ce qui augmente les risques de pivot en cas de machine compromise.

Dans une optique de sécurité maximale avec ergonomie acceptable, le full tunnel est privilégié.

3.1.4. Dimensionnement fonctionnel

La solution vise environ 50 utilisateurs potentiels (utilisateurs classiques + admins), ce qui reste largement dans les capacités de pfSense + OpenVPN sur une VM correctement dimensionnée.

Aucun prestataire externe n'est prévu, ce qui évite la création de profils spécifiques et simplifie la gestion des accès.

3.1.5. Contraintes et coûts

Contraintes de performances non critiques dans ce contexte, le trafic attendu reste modéré.

Coût :

- Pfsense et OpenVPN sont gratuits (open source) ;
- La seule charge réside dans le temps d'administration et la maintenance de la VM.

En comparaison, une solution FortiGate/FortiClient ou Sophos Firewall impliquerait :

- L'acquisition d'une appliance ou d'une VM sous licence ;
- La souscription à des contrats de support et, souvent, à des modules de sécurité supplémentaires ;
- Une dépendance forte à l'écosystème du constructeur.

3.2. Définition des zones réseau et de leur rôle

3.2.1. Réseau local (LAN)

Le LAN de production est en 192.168.1.0/24, avec :

- Passerelle pfSense en 192.168.1.1
- Serveur AD/DNS en 192.168.1.19
- Serveur de fichiers en 192.168.1.20

3.2.2. Réseau dédié aux clients VPN

Les clients VPN utilisent un réseau dédié VPN Clients : 10.10.10.0/24.

- Pfsense/OpenVPN est configuré pour attribuer à chaque utilisateur un sous-réseau /30 distinct (une adresse client, une adresse côté pfSense) ;
- L'option d'isolation client-client est activée, empêchant les communications directes entre clients VPN.

Client Settings	
Dynamic IP	☒ Allow connected clients to retain their connections if their IP address changes.
Topology	net30 – Isolated /30 network per client Specifies the method used to supply a virtual adapter IP address to clients when using TUN mode on IPv4. Some clients may require this be set to "subnet" even for IPv6, such as OpenVPN Connect (iOS/Android). Older versions of OpenVPN (before 2.0.9) or clients such as Yealink phones may require "net30".

Depuis ce réseau VPN, on n'autorise que les flux nécessaires vers :

- Le serveur AD/DNS (192.168.1.19) ;
- Le serveur de fichiers (192.168.1.20).

3.2.4. Règles de filtrage entre les zones

Depuis le réseau VPN_Clients (10.10.10.0/24) :

- Vers le LAN :
 - Autorisation vers 192.168.1.19 (DNS/LDAPS) ;
 - Autorisation vers 192.168.1.20 (SMB) ;
 - Blocage de tout autre flux vers les postes ou serveurs non nécessaires ;

- Vers Internet :
 - Autorisation via pfSense, de manière à appliquer les règles de filtrage de l'entreprise (full tunnel).

3.2.5. Accès d'administration

L'administration de pfSense est possible uniquement depuis le VLAN admin interne (déjà existant, interconnecté par routage inter-VLAN).

Aucun accès d'administration n'est autorisé ni depuis le VPN ni depuis Internet, ce qui est une bonne pratique quel que soit le constructeur (pfSense, Fortinet, Sophos...).

3.3. Plan d'adressage IP

3.3.1. Rappels

- LAN : 192.168.1.0/24
- WAN : 172.16.9.230 (pfSense)
- VPN : 10.10.10.0/24

3.3.2. Plage VPN et sous-réseaux /30

Le réseau VPN 10.10.10.0/24 est découpé en sous-réseaux /30 attribués dynamiquement à chaque client via OpenVPN afin d'isoler chaque utilisateur.

3.3.3. Routage

Pfsense est la passerelle pour le LAN et le réseau VPN. Il assure :

- Le routage entre 10.10.10.0/24 et 192.168.1.0/24 (vers les serveurs autorisés) ;
- Le NAT vers Internet pour les flux LAN et VPN.

3.3.4. Conflits d'adressage

L'utilisation d'une plage 10.x.x.x distincte du LAN évite les problèmes de conflit si l'utilisateur se connecte depuis un réseau domestique en 192.168.x.x. Cette bonne pratique est valable quelle que soit la solution VPN utilisée (pfSense, Fortinet, Sophos, etc.).

3.3.5. Réservations

Pas de réservations particulières en dehors des IP fixes des serveurs et de pfSense. Les adresses VPN sont gérées par OpenVPN.

3.4. Stratégie d'authentification et de gestion des droits

3.4.1. Source d'authentification : LDAPS vers Active Directory

L'authentification VPN passe par LDAPS : pfSense interroge le contrôleur de domaine (192.168.1.19) pour valider les identifiants des utilisateurs.

Avantage clé :

- Gestion centralisée des identités (création/suppression de comptes) ;
- Réutilisation des politiques AD (complexité, expiration, verrouillage)

Les appliances Fortinet/Sophos fonctionnent de manière similaire (intégration LDAP/RADIUS), mais pfSense permet de le faire sans surcoût logiciel.

3.4.2. Certificats utilisateurs et MFA

Chaque utilisateur dispose d'un certificat client généré via la PKI interne de pfSense, utilisé en plus de son compte AD.

- Authentification à deux facteurs techniques : certificat + mot de passe AD ;
- Meilleure protection en cas de fuite de mot de passe simple.

La mise en place d'un MFA complet (TOTP, push, FIDO2) est prévue comme recommandation pour une future évolution, de la même manière que sur des solutions Fortinet/Sophos qui intègrent souvent des options MFA natives (token, app mobile).

3.4.3. Groupes AD et périmètre VPN

L'accès VPN est contrôlé par des groupes AD dédiés (VPN_USERS).

Seuls les membres de ces groupes peuvent s'authentifier sur le VPN.

La différenciation des droits (accès aux dossiers partagés) reste gérée par les ACL et les groupes AD existants, ce qui évite de multiplier les profils VPN côté pare-feu.

3.4.4. Politiques de mots de passe et verrouillage

Les GPO de l'AD (complexité, longueur, durée de vie, verrouillage après tentatives échouées) s'appliquent automatiquement aux comptes VPN. C'est une approche conforme aux recommandations ANSSI et comparable à ce que l'on mettrait en œuvre avec Fortinet/Sophos couplés à un AD.

3.4.5. Gestion des comptes

Le service IT gère :

- La création des comptes AD et leur intégration dans les groupes VPN ;
- La désactivation des comptes lors des départs ;
- La révocation des certificats VPN en cas de compromission ou de perte de matériel.

3.5. Schéma physique et logique de la solution VPN

3.5.1. Plateforme

Pfsense est déployé sous forme de VM :

- Carte réseau externe pour le WAN ;
- Carte réseau connectée au commutateur virtuel LAN_ADRAF pour le LAN.

Ce choix permet une grande souplesse (snapshots, restauration rapide, tests) et ne nécessite pas d'appliance matérielle dédiée, contrairement à la plupart des solutions Fortinet/Sophos en production.

3.5.2. Positionnement

La topologie globale :

Internet → Interface WAN pfSense (172.16.9.230) → pfSense (firewall + OpenVPN) → Interface LAN (192.168.1.1) → LAN (192.168.1.0/24).

Pfsense concentre :

- La terminaison des tunnels OpenVPN ;
- Le filtrage entre VPN, LAN et Internet ;
- Le NAT pour les différentes zones.

3.5.3. Schéma réseau

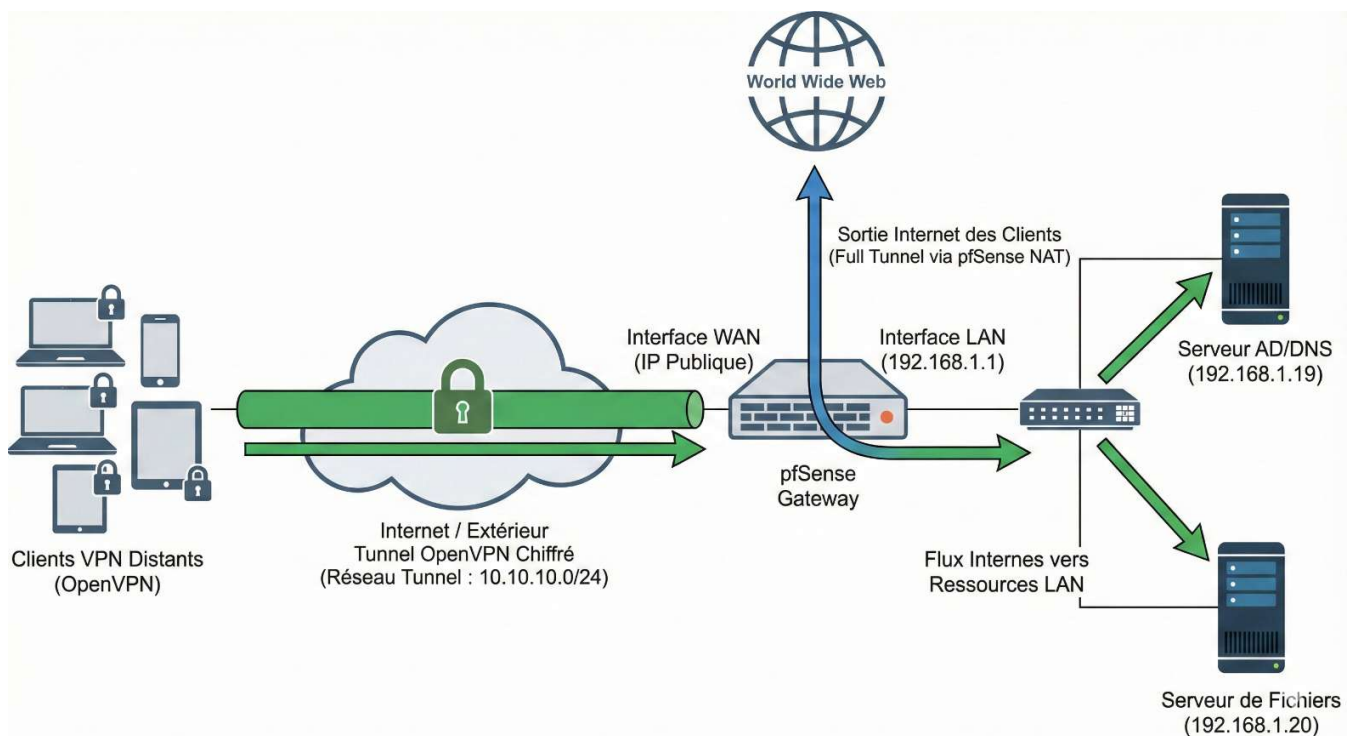


Schéma de principe : Architecture d'accès distant sécurisé OpenVPN (mode "Full Tunnel")

3.5.4. Haute disponibilité (recommandation)

Actuellement, pfSense est un point unique de défaillance (SPOF).

Recommandation pour un environnement de production :

- Déployer un cluster pfSense en CARP (2 VM sur 2 hôtes différents avec une adresse IP commune)
- Prévoir un second lien WAN (multi-opérateur) pour la résilience

Les constructeurs comme Fortinet ou Sophos proposent nativement ce type de HA (clusters actifs/passifs), mais pfSense sait aussi le gérer, sans frais de licences supplémentaires, au prix d'un peu plus de configuration.

3.6. Résumé des choix techniques

Les choix techniques réalisés sont cohérents avec :

- Les objectifs de sécurité de l'entreprise
- Les contraintes de coût

Pourquoi pfSense + OpenVPN plutôt qu'une appliance Fortinet/Sophos ?

- Coût : pfSense + OpenVPN = pas de licence, parfait pour une PME.
- Fortinet/Sophos impliquent des licences, des renouvellements et parfois des fonctionnalités payantes pour des options avancées.
- Flexibilité / ouverture : pfSense est très configurable, ne verrouille pas l'architecture et permet d'expérimenter facilement différentes topologies (lab, maquettes).
- Pédagogie : l'interface et les logs d'OpenVPN sur pfSense sont bien adaptés pour comprendre le fonctionnement d'un VPN SSL, ce qui est un objectif important du projet.
- Capacités : pour un environnement à 50 utilisateurs avec un seul site, pfSense offre des fonctionnalités comparables à celles d'appliances commerciales, en restant largement suffisant en termes de performance.

Pourquoi OpenVPN plutôt que WireGuard ou IPsec ?

- OpenVPN : très largement supporté, extrêmement documenté, hautement configurable.
- IPsec IKEv2 : excellent pour du site-à-site et du nomade, très performant, mais plus complexe à appréhender pour un premier projet.
- WireGuard : plus rapide et plus moderne, mais encore moins répandu dans les environnements d'entreprise "classiques" ; certaines questions de gestion des clés, de journalisation et d'intégration AD sont moins triviales, surtout pour un projet orienté pédagogie.

Le projet assume donc un compromis :

- Sécurité élevée (chiffrement fort, certificats, LDAPS, segmentation, full tunnel) ;
- Mise en œuvre réaliste pour une PME, reproductible en environnement d'école ;
- Base technique suffisamment standard pour être transposable plus tard vers une solution Fortinet/Sophos, si l'entreprise choisissait d'évoluer vers une appliance propriétaire.

Les limites assumées sont :

- Pas de MFA implémenté pour l'instant (mais recommandé) ;
- Pas de haute disponibilité (recommandée dans la section améliorations) ;
- Supervision limitée à la journalisation VPN sans SIEM avancé.

3.7. Conclusion sur la conception

L'architecture choisie (pfSense + OpenVPN, réseau VPN dédié 10.10.10.0/24, intégration AD via LDAPS, full tunnel) répond :

- Au besoin fonctionnel : permettre à 50 utilisateurs max de se connecter à distance comme s'ils étaient sur site, avec les mêmes droits sur le serveur de fichiers ;
- Aux exigences de sécurité : chiffrement fort, segmentation des flux, limitation des accès, isolation client-client, intégration AD, contrôle centralisé de la sortie Internet ;
- Aux contraintes de coût : solution open source sans coût de licence, adaptée à une PME ou à un projet pédagogique.

En comparaison avec des solutions Fortinet / Sophos / WireGuard :

- PfSense + OpenVPN est moins coûteux, très flexible et bien adapté à un environnement unique de taille modérée ;
- Les appliances commerciales apporteraient surtout du support constructeur et des fonctionnalités additionnelles (admin centralisée multi-sites, SD-WAN, etc.) qui dépassent le périmètre de ce projet ;
- WireGuard pourrait offrir de meilleures performances, mais au prix d'un écart plus important avec les environnements "classiques" que rencontrera un administrateur système débutant.

Cette conception constitue donc une base solide et cohérente, tout en laissant la porte ouverte à des évolutions (MFA, HA, SIEM, migration éventuelle vers une appliance propriétaire) qui seront évoquées dans les axes d'amélioration en fin de rapport.

Section 4 – Mise en œuvre et configuration des services

4.1. Mise en œuvre réseau — pfSense, routage et filtrage

4.1.1. Configuration des interfaces pfSense

La VM pfSense est déployée sur Hyper-V avec deux interfaces :

- **WAN** : connectée au réseau externe (commutateur virtuel “externe”)
 - Adresse : 172.16.9.230
 - Rôle : passerelle vers Internet
- **LAN** : connectée au réseau interne (commutateur virtuel “LAN_ADRAF”)
 - Adresse : 192.168.1.1
 - Rôle : passerelle par défaut du LAN 192.168.1.0/24, point d’entrée des flux VPN vers le réseau interne.

4.1.2. NAT et accès à Internet

Un NAT sortant est configuré sur pfSense pour permettre aux postes du LAN (192.168.1.0/24) et aux futurs clients VPN (10.10.10.0/24) d’accéder à Internet via l’adresse WAN 172.16.9.230.

Le pare-feu est configuré en mode “Automatic outbound NAT rule generation (IPsec passthrough included)”.

Dans ce mode, pfSense :

- détecte automatiquement les réseaux internes (LAN 192.168.1.0/24, réseau VPN 10.10.10.0/24, etc.) ;
- génère tout seul les règles de NAT sortant nécessaires pour que ces réseaux puissent sortir sur Internet via l’IP WAN 172.16.9.230 ;
- évite ainsi les erreurs de configuration et réduit la charge d’administration, ce qui est parfaitement adapté à une architecture simple avec un seul pare-feu et un seul lien Internet.

Outbound NAT Mode				
Mode	☒	☐	☐	☐
	Automatic outbound NAT rule generation. (IPsec passthrough included)	Hybrid Outbound NAT rule generation. (Automatic Outbound NAT + rules below)	Manual Outbound NAT rule generation. (AON - Advanced Outbound NAT)	Disable Outbound NAT rule generation. (No Outbound NAT rules)

4.1.3. Règles de filtrage de base

Les règles de firewall sur pfSense sont structurées ainsi :

- **Interface LAN**
 - Règle “LAN → Any” (sortie) pour autoriser les postes internes à sortir vers Internet et vers le réseau VPN, selon la politique globale de l’entreprise (possibilité de restreindre plus finement si nécessaire).
- **Interface WAN**
 - Blocage par défaut de tous les flux entrants ;
 - Ouverture ciblée **uniquement** du port utilisé par OpenVPN (UDP, port 1194), depuis Internet vers pfSense.
- **Interface OpenVPN** (créée automatiquement après configuration du serveur VPN)
 - Règles permettant :
 - l’accès des clients VPN à 192.168.1.19 (AD/DNS) ;
 - l’accès à 192.168.1.20 (serveur de fichiers) ;
 - la sortie vers Internet (full tunnel) via le WAN.

Ces règles sont volontairement **restrictives** : le réseau VPN ne voit que les serveurs nécessaires, et aucun accès direct aux autres postes du LAN n’est autorisé.

4.2. Configuration des services Windows (AD / DNS / LDAPS)

Le domaine Active Directory utilisé est **adraf.lan** avec le contrôleur de domaine **DC-01** (192.168.1.19).

4.2.1. Rôle du contrôleur de domaine

DC-01 assure :

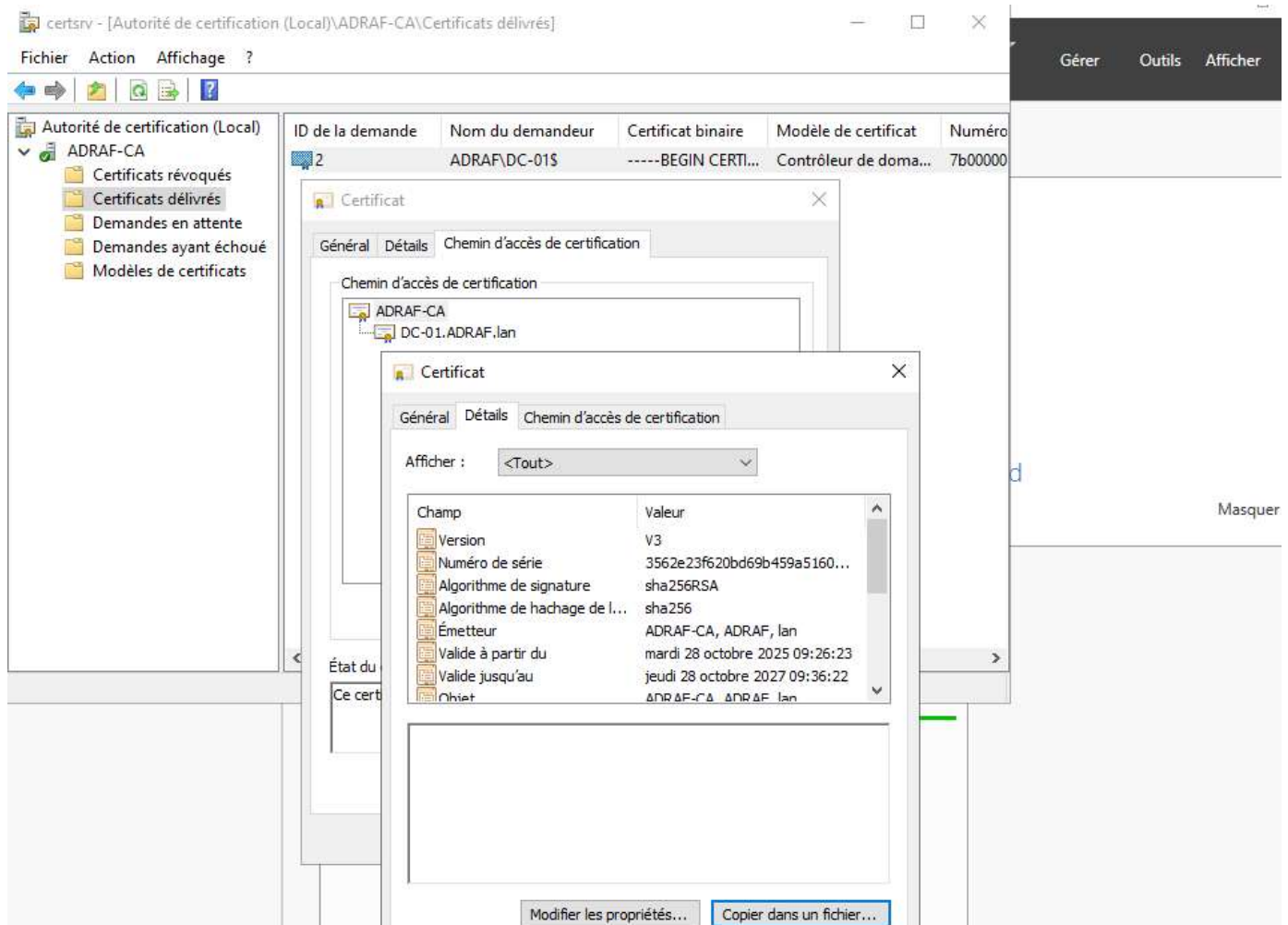
- Les fonctions de **contrôleur de domaine** (authentification Kerberos/NTLM) ;
- Le rôle **DNS interne** pour la résolution des noms du domaine adraf.lan

Tous les utilisateurs disposent d’un **compte AD** utilisé à la fois pour la session Windows locale et pour l’authentification VPN.

4.2.2. Mise en place de LDAPS

Pour sécuriser les échanges entre pfSense et l'AD, le **LDAP sur SSL (LDAPS)** est activé :

1. Création d'un **certificat serveur** pour DC-01, émis par l'Autorité de Certification interne (ou auto-signée pour le projet).



2. Activation de **LDAPS** (TCP/636) sur DC-01, via les outils de gestion AD/Certificats.

Server Settings	
<u>Descriptive name</u>	LDAP_Server
<u>Type</u>	LDAP

LDAP Server Settings	
<u>Hostname or IP address</u>	DC-01.adraf.lan NOTE: When using SSL/TLS or STARTTLS, this hostname MUST match a Subject Alternative Name (SAN) or the Common Name (CN) of the LDAP server SSL/TLS Certificate.
<u>Port value</u>	636
<u>Transport</u>	SSL/TLS Encrypted
<u>Peer Certificate Authority</u>	CA-ADRAF.lan This CA is used to validate the LDAP server certificate when 'SSL/TLS Encrypted' or 'STARTTLS Encrypted' Transport is active. This CA must match the CA used by the LDAP server.
<u>Protocol version</u>	3
<u>Server Timeout</u>	25 Timeout for LDAP operations (seconds)
<u>Search scope</u>	Level Entire Subtree Base DN DC=ADRAF,DC=lan

3. Vérification depuis pfSense que la connexion LDAPS à 192.168.1.19:636 fonctionne (test via l'interface "Diagnostics → Authentication").

User l.stiti authenticated successfully. This user is a member of groups:

Authentication Test	
<u>Authentication Server</u>	LDAP_Server Select the authentication server to test against.
<u>Username</u>	l.stiti
<u>Password</u>	
<u>Debug</u>	☐ Set debug flag Sets the debug flag when performing authentication, which may trigger additional diagnostic entries in the system log (e.g. for LDAP).

Dans pfSense, le **serveur d'authentification LDAPS** est configuré :

- Adresse : 192.168.1.19
- Port : 636
- Base DN : correspondant au domaine adraf.lan
- Utilisation de TLS/SSL cochée, avec vérification du certificat.

Server Settings	
Descriptive name	LDAP_Server
Type	LDAP
LDAP Server Settings	
Hostname or IP address	DC-01.adraf.lan NOTE: When using SSL/TLS or STARTTLS, this hostname MUST match a Subject Alternative Name (SAN) or the Common Name (CN) of the LDAP server SSL/TLS Certificate.
Port value	636
Transport	SSL/TLS Encrypted
Peer Certificate Authority	CA-ADRAF.lan This CA is used to validate the LDAP server certificate when 'SSL/TLS Encrypted' or 'STARTTLS Encrypted' Transport is active. This CA must match the CA used by the LDAP server.
Protocol version	3
Server Timeout	25 Timeout for LDAP operations (seconds)
Search scope	Level Entire Subtree
	Base DN DC=ADRAF,DC=lan

Comparaison : LDAPS vs LDAP simple / RADIUS

- **LDAP simple** (port 389) n'offre pas de chiffrement par défaut : les identifiants pourraient circuler en clair si on n'active pas StartTLS. LDAPS est donc nettement plus adapté à un contexte sécurisé.
- **RADIUS** (par exemple NPS Microsoft) est très intéressant pour centraliser toutes les authentifications réseau, mais ajoute une couche supplémentaire (serveur NPS, configuration RADIUS sur pfSense). Pour ce projet, LDAPS direct est un bon compromis entre sécurité et simplicité.

4.2.3. Groupes AD pour le VPN

Un **groupe de sécurité AD** est créé :

- VPN_USERS



Seuls les utilisateurs membres de ce groupe sont autorisés à se connecter au VPN. Ce filtrage sera utilisé côté pfSense, au niveau de la configuration OpenVPN + LDAPS.

Select LDAP containers for authentication

- Containers
- ☐ OU=Administratif,OU=ADRAF,DC=ADRAF,DC=lan
 - ☐ OU=ADRAF,DC=ADRAF,DC=lan
 - ☐ OU=Domain Controllers,DC=ADRAF,DC=lan
 - ☐ OU=Formateurs,OU=ADRAF,DC=ADRAF,DC=lan
 - ☐ OU=Groups,OU=Stagiaires,OU=ADRAF,DC=ADRAF,DC=lan
 - ☐ OU=Groups,OU=IT,OU=ADRAF,DC=ADRAF,DC=lan
 - ☐ OU=Groups,OU=Administratif,OU=ADRAF,DC=ADRAF,DC=lan
 - ☐ OU=Groups,OU=Formateurs,OU=ADRAF,DC=ADRAF,DC=lan
 - ☐ OU=IT,OU=ADRAF,DC=ADRAF,DC=lan
 - ☐ OU=Stagiaires,OU=ADRAF,DC=ADRAF,DC=lan
 - ☐ OU=Users,OU=Stagiaires,OU=ADRAF,DC=ADRAF,DC=lan
 - ☐ OU=Users,OU=IT,OU=ADRAF,DC=ADRAF,DC=lan
 - ☐ OU=Users,OU=Formateurs,OU=ADRAF,DC=ADRAF,DC=lan
 - ☐ OU=Users,OU=Administratif,OU=ADRAF,DC=ADRAF,DC=lan
 - ☒ OU=VPN_USERS,DC=ADRAF,DC=lan
 - ☐ CN=Users,DC=ADRAF,DC=lan



Les droits d'accès au **serveur de fichiers** (192.168.1.20) restent gérés comme en interne :

- groupes AD par service / équipe ;
- Droits NTFS sur les dossiers partagés.

4.3. Passerelle VPN – Installation et configuration OpenVPN

4.3.1. Mise en place de la PKI interne dans pfSense

OpenVPN s'appuie sur une infrastructure à clés publiques (PKI) pour gérer :

- Un **certificat serveur** (pour pfSense)
- Des **certificats clients** pour chaque utilisateur VPN.

Dans pfSense :

1. Création d'une **Autorité de Certification (CA)** interne.
2. Génération d'un **certificat serveur** OpenVPN signé par cette CA.

Certificate Authorities						
Name	Internal	Issuer	Certificates	Distinguished Name	In Use	Actions
CA-ADRAF.lan	✗	self-signed	0	DC=ADRAF, DC=lan, CN=ADRAF-CA ⓘ Valid From: Tue, 28 Oct 2025 11:27:12 +0100 Valid Until: Thu, 28 Oct 2027 12:37:11 +0200	LDAP Server	 
CA-ADRAF-VPN	✓	self-signed	2	CN=internal-ca ⓘ Valid From: Mon, 17 Nov 2025 14:44:42 +0100 Valid Until: Thu, 15 Nov 2035 14:44:42 +0100	OpenVPN Server	   

3. Génération d'un **certificat client**.

Certificates				
Name	Issuer	Distinguished Name	In Use	Actions
GUI default (691af8f10be37) Server Certificate CA: No Server: Yes	self-signed	O=pfSense GUI default Self-Signed Certificate, CN=pfSense-691af8f10be37 Valid From: Mon, 17 Nov 2025 11:29:05 +0100 Valid Until: Sun, 20 Dec 2026 11:29:05 +0100	 DNS Resolver	   
OPENVPN-ADRAF Server Certificate CA: No Server: Yes	CA-ADRAF-VPN	CN=internal-ca Valid From: Mon, 17 Nov 2025 15:00:19 +0100 Valid Until: Thu, 15 Nov 2035 15:00:19 +0100	OpenVPN Server	   
VPN-USER User Certificate CA: No Server: No	CA-ADRAF-VPN	CN=internal-ca Valid From: Mon, 17 Nov 2025 15:03:03 +0100 Valid Until: Thu, 15 Nov 2035 15:03:03 +0100	User Cert	   

Comparaison avec un VPN IPsec pré-partagé (PSK)

- Un déploiement IPsec “rapide” utilise souvent un **secret partagé (PSK)** pour tous les clients, ce qui est moins sécurisé : si le PSK fuit, tous les tunnels sont potentiellement compromis.
- Le couple **OpenVPN + certificats** offre un meilleur contrôle des identités, à un niveau de complexité acceptable dans pfSense grâce à l’interface de gestion de certs intégrée.

4.3.2. Création du serveur OpenVPN

Un serveur OpenVPN de type “**Remote Access (SSL/TLS + User Auth)**” est créé :

- **Interface de liaison** : WAN pfSense ;
- **Port/Protocole** : UDP/1194 (par exemple) ;
- **Réseau VPN** : 10.10.10.0/24 ;
- **Mode d’allocation** : un sous-réseau /30 par client ;
- **Serveur DNS attribué aux clients** : 192.168.1.19 (DC-01) ;
- **Authentification** :
 - Certificat client + utilisateur/mot de passe AD via LDAPS.

OpenVPN Servers					
Interface	Protocol / Port	Tunnel Network	Mode / Crypto	Description	Actions
WAN	UDP4 / 1194 (TUN)	10.10.10.0/24	Mode: Remote Access (SSL/TLS + User Auth) Data Ciphers: AES-256-GCM, AES-128-GCM, CHACHA20-POLY1305, AES-256-CBC Digest: SHA256 D-H Params: 2048 bits	OPENVPN	  

General Information	
Description	OPENVPN A description of this VPN for administrative reference.
Disabled	☐ Disable this server Set this option to disable this server without removing it from the list.
Unique VPN ID	Server 1 (ovpns1)
Mode Configuration	
Server mode	Remote Access (SSL/TLS + User Auth)
Backend for authentication	LDAP_Server Local Database
Device mode	tun - Layer 3 Tunnel Mode "tun" mode carries IPv4 and IPv6 (OSI layer 3) and is the most common and compatible mode across all platforms. "tap" mode is capable of carrying 802.3 (OSI Layer 2.)
Endpoint Configuration	
Protocol	UDP on IPv4 only
Interface	WAN The interface or Virtual IP address where OpenVPN will receive client connections.
Local port	1194
Cryptographic Settings	
TLS Configuration	☒ Use a TLS Key A TLS key enhances security of an OpenVPN connection by requiring both parties to have a common key before a peer can perform a TLS handshake. This layer of HMAC authentication allows control channel packets without the proper key to be dropped, protecting the peers from attack or unauthorized connections. The TLS Key does not have any effect on tunnel data.
TLS Key	<pre># # 2048 bit OpenVPN static key # -----BEGIN OpenVPN Static key V1----- 8057ac754ae0836ff7f912a10b4110b3</pre> Paste the TLS key here. This key is used to sign control channel packets with an HMAC signature for authentication when establishing the tunnel.
TLS Key Usage Mode	TLS Authentication In Authentication mode the TLS key is used only as HMAC authentication for the control channel, protecting the peers from unauthorized connections. Encryption and Authentication mode also encrypts control channel communication, providing more privacy and traffic control channel obfuscation.
TLS keydir direction	Use default direction The TLS Key Direction must be set to complementary values on the client and server. For example, if the server is set to 0, the client must be set to 1. Both may be set to omit the direction, in which case the TLS Key will be used bidirectionally.
Peer Certificate Authority	CA-ADRAF-VPN
Peer Certificate Revocation list	No Certificate Revocation Lists defined. One may be created here: System > Cert. Manager
OCSP Check	☐ Check client certificates with OCSP
Server certificate	OPENVPN-ADRAF (Server: Yes, CA: CA-ADRAF-VPN, In Use) Certificates known to be incompatible with use for OpenVPN are not included in this list, such as certificates using incompatible ECDSA curves or weak

DH Parameter Length	2048 bit Diffie-Hellman (DH) parameter set used for key exchange. ?	
ECDH Curve	Use Default The Elliptic Curve to use for key exchange. The curve from the server certificate is used by default when the server uses an ECDSA certificate. Otherwise, secp384r1 is used as a fallback.	
Data Encryption Algorithms	AES-128-CBC (128 bit key, 128 bit block) AES-128-CFB (128 bit key, 128 bit block) AES-128-CFB1 (128 bit key, 128 bit block) AES-128-CFB8 (128 bit key, 128 bit block) AES-128-GCM (128 bit key, 128 bit block) AES-128-OFB (128 bit key, 128 bit block) AES-192-CBC (192 bit key, 128 bit block) AES-192-CFB (192 bit key, 128 bit block) AES-192-CFB1 (192 bit key, 128 bit block) AES-192-CFB8 (192 bit key, 128 bit block) Available Data Encryption Algorithms Click to add or remove an algorithm from the list	AES-256-GCM AES-128-GCM CHACHA20-POLY1305 Allowed Data Encryption Algorithms. Click an algorithm name to remove it from the list
The order of the selected Data Encryption Algorithms is respected by OpenVPN. This list is ignored in Shared Key mode. ?		
Fallback Data Encryption Algorithm	AES-256-CBC (256 bit key, 128 bit block) The Fallback Data Encryption Algorithm used for data channel packets when communicating with clients that do not support data encryption algorithm negotiation (e.g. Shared Key). This algorithm is automatically included in the Data Encryption Algorithms list.	
Auth digest algorithm	SHA256 (256-bit) The algorithm used to authenticate data channel packets, and control channel packets if a TLS Key is present. When an AEAD Encryption Algorithm mode is used, such as AES-GCM, this digest is used for the control channel only, not the data channel. The server and all clients must have the same setting. While SHA1 is the default for OpenVPN, this algorithm is insecure.	
Certificate Depth	One (Client+Server) When a certificate-based client logs in, do not accept certificates below this depth. Useful for denying certificates made with intermediate CAs	
Client Certificate Key Usage Validation	☒ Enforce key usage Verify that only hosts with a client certificate can connect (EKU: "TLS Web Client Authentication").	

Tunnel Settings

IPv4 Tunnel Network	10.10.10.0/24 This is the IPv4 virtual network or network type alias with a single entry used for private communications between this server and client hosts expressed using CIDR notation (e.g. 10.0.8.0/24). The first usable address in the network will be assigned to the server virtual interface. The remaining usable addresses will be assigned to connecting clients. A tunnel network of /30 or smaller puts OpenVPN into a special peer-to-peer mode which cannot push settings to clients. This mode is not compatible with several options, including Exit Notify, and Inactive.
IPv6 Tunnel Network	This is the IPv6 virtual network or network type alias with a single entry used for private communications between this server and client hosts expressed using CIDR notation (e.g. fe80::/64). The ::1 address in the network will be assigned to the server virtual interface. The remaining addresses will be assigned to connecting clients.
Redirect IPv4 Gateway	☐ Force all client-generated IPv4 traffic through the tunnel.
Redirect IPv6 Gateway	☐ Force all client-generated IPv6 traffic through the tunnel.
IPv4 Local network(s)	192.168.1.0/24 IPv4 networks that will be accessible from the remote endpoint. Expressed as a comma-separated list of one or more CIDR ranges or host/network type aliases. This may be left blank if not adding a route to the local network through this tunnel on the remote machine. This is generally set to the LAN network.
IPv6 Local network(s)	IPv6 networks that will be accessible from the remote endpoint. Expressed as a comma-separated list of one or more IP/PREFIX or host/network type aliases. This may be left blank if not adding a route to the local network through this tunnel on the remote machine. This is generally set to the LAN network.

Client Settings	
Dynamic IP	☒ Allow connected clients to retain their connections if their IP address changes.
Topology	net30 – Isolated /30 network per client Specifies the method used to supply a virtual adapter IP address to clients when using TUN mode on IPv4. Some clients may require this be set to "subnet" even for IPv6, such as OpenVPN Connect (iOS/Android). Older versions of OpenVPN (before 2.0.9) or clients such as Yealink phones may require "net30".
Ping settings	
Inactivity Timeout	300 Causes OpenVPN to close a client connection after n seconds of inactivity on the TUN/TAP device. Activity is based on the last incoming or outgoing tunnel packet. A value of 0 disables this feature. This option is ignored in Peer-to-Peer Shared Key mode and in SSL/TLS mode with a blank or /30 tunnel network as it will cause the server to exit and not restart.
Ping method	keepalive – Use keepalive helper to define ping configuration keepalive helper uses interval and timeout parameters to define ping and ping-restart values as follows: ping = interval ping-restart = timeout*2 push ping = interval push ping-restart = timeout
Interval	10
Timeout	60
Advanced Client Settings	
DNS Default Domain	☒ Provide a default domain name to clients
Advanced Client Settings	
DNS Default Domain	☒ Provide a default domain name to clients
DNS Default Domain	adraf.lan
DNS Server enable	☒ Provide a DNS server list to clients. Addresses may be IPv4 or IPv6.
DNS Server 1	192.168.1.19
DNS Server 2	
DNS Server 3	
DNS Server 4	
Block Outside DNS	☐ Make Windows 10 Clients Block access to DNS servers except across OpenVPN while connected, forcing clients to use only VPN DNS servers. Requires Windows 10 and OpenVPN 2.3.9 or later. Only Windows 10 is prone to DNS leakage in this way, other clients will ignore the option as they are not affected.
Force DNS cache update	☐ Run "net stop dnscache", "net start dnscache", "ipconfig /flushdns" and "ipconfig /registerdns" on connection initiation. This is known to kick Windows into recognizing pushed DNS servers.
NTP Server enable	☐ Provide an NTP server list to clients
NetBIOS enable	☐ Enable NetBIOS over TCP/IP If this option is not set, all NetBIOS-over-TCP/IP options (including WINS) will be disabled.
Advanced Configuration	

Advanced Configuration

Custom options

auth-nocache

Enter any additional options to add to the OpenVPN server configuration here, separated by semicolon.
EXAMPLE: push "route 10.0.0.0 255.255.255.0"

Username as Common Name

☐ Use the authenticated client username instead of the certificate common name (CN).
When a user authenticates, if this option is enabled then the username of the client will be used in place of the certificate common name for purposes such as determining Client Specific Overrides.

UDP Fast I/O

☐ Use fast I/O operations with UDP writes to tun/tap. Experimental.
Optimizes the packet write event loop, improving CPU efficiency by 5% to 10%. Not compatible with all platforms, and not compatible with OpenVPN bandwidth limiting.

Exit Notify

Reconnect to this server / Retry once

Send an explicit exit notification to connected clients/peers when restarting or shutting down, so they may immediately disconnect rather than waiting for a timeout. In SSL/TLS Server modes, clients may be directed to reconnect or use the next server. This option is ignored in Peer-to-Peer Shared Key mode and in SSL/TLS mode with a blank or /30 tunnel network as it will cause the server to exit and not restart.

Send/Receive Buffer

Default

Configure a Send and Receive Buffer size for OpenVPN. The default buffer size can be too small in many cases, depending on hardware and network uplink speeds. Finding the best buffer size can take some experimentation. To test the best value for a site, start at 512KiB and test higher and lower values.

Gateway creation

☒ Both
☐ IPv4 only
☐ IPv6 only

If you assign a virtual interface to this OpenVPN server, this setting controls which gateway types will be created. The default setting is 'both'.

Verbosity level

3 (recommended)

Each level shows all info from the previous levels. Level 3 is recommended for a good summary of what's happening without being swamped by output.

None: Only fatal errors
Default through 4: Normal usage range
5: Output R and W characters to the console for each packet read and write. Uppercase is used for TCP/UDP packets and lowercase is used for TUN/TAP packets.
6-11: Debug info range

Captures d'écran de la configuration du serveur OpenVPN

Les options de sécurité sont configurées de manière stricte :

- algorithme de chiffrement **AES** (256 bits)
- intégrité **SHA-256**
- désactivation des versions obsolètes de TLS.

Comparaison avec WireGuard

- WireGuard serait plus simple à configurer au niveau crypto (moins de paramètres), mais sa gestion multi-utilisateurs / intégration AD nécessite plus de travail "à la main". OpenVPN sur pfSense, grâce à l'assistant, est plus **directement exploitable** pour un environnement AD et 50 utilisateurs.

4.3.3. Règles de firewall OpenVPN

Une fois le serveur créé, pfSense ajoute une interface logique **OpenVPN**.

Les règles suivantes sont définies sur cette interface :

- Autorisation du trafic VPN_Clients → 192.168.1.19 (ports DNS, LDAP/LDAPS).
- Autorisation du trafic VPN_Clients → 192.168.1.20 (ports SMB).
- Autorisation du trafic VPN_Clients → Any vers WAN pour la navigation Internet.
- Blocage de tout autre trafic vers le LAN.

Cette configuration assure :

- un accès **strictement limité** aux serveurs nécessaires ;
- un **full tunnel** pour la sortie Internet, permettant d'appliquer les politiques de filtrage du pare-feu d'entreprise aux utilisateurs distants.

4.4. Postes clients — Configuration et tests de connexion

4.4.1. Déploiement du client OpenVPN

Sur les postes nomades (Windows), le **client OpenVPN** est installé :

1. Installation du logiciel OpenVPN Client.
2. Import du **profil de connexion (.ovpn)** généré par pfSense, incluant :
 - l'adresse du serveur (IP WAN ou nom DNS public pointant sur 172.16.9.230) ;
 - les paramètres de chiffrement ;
 - les certificats CA et client nécessaires.

OpenVPN Clients		
User	Certificate Name	Export
Certificate with External Auth	VPN-USER	- Inline Configurations: Most Clients Android OpenVPN Connect (iOS/Android) - Bundled Configurations: Archive Config File Only - Current Windows Installer (2.6.7-1x001): 64-bit 32-bit - Previous Windows Installer (2.5.9-1x601): 64-bit 32-bit - Legacy Windows Installers (2.4.12-1x601): 10/2016/2019 7/8/8.1/2012r2 - Viscosity (Mac OS X and Windows): Viscosity Bundle Viscosity Inline Config

Les certificats clients peuvent être :

- soit intégrés au fichier de configuration ;
- soit déployés séparément dans le magasin de certificats du poste.

4.4.2. Procédure de connexion utilisateur

La procédure typique côté utilisateur :

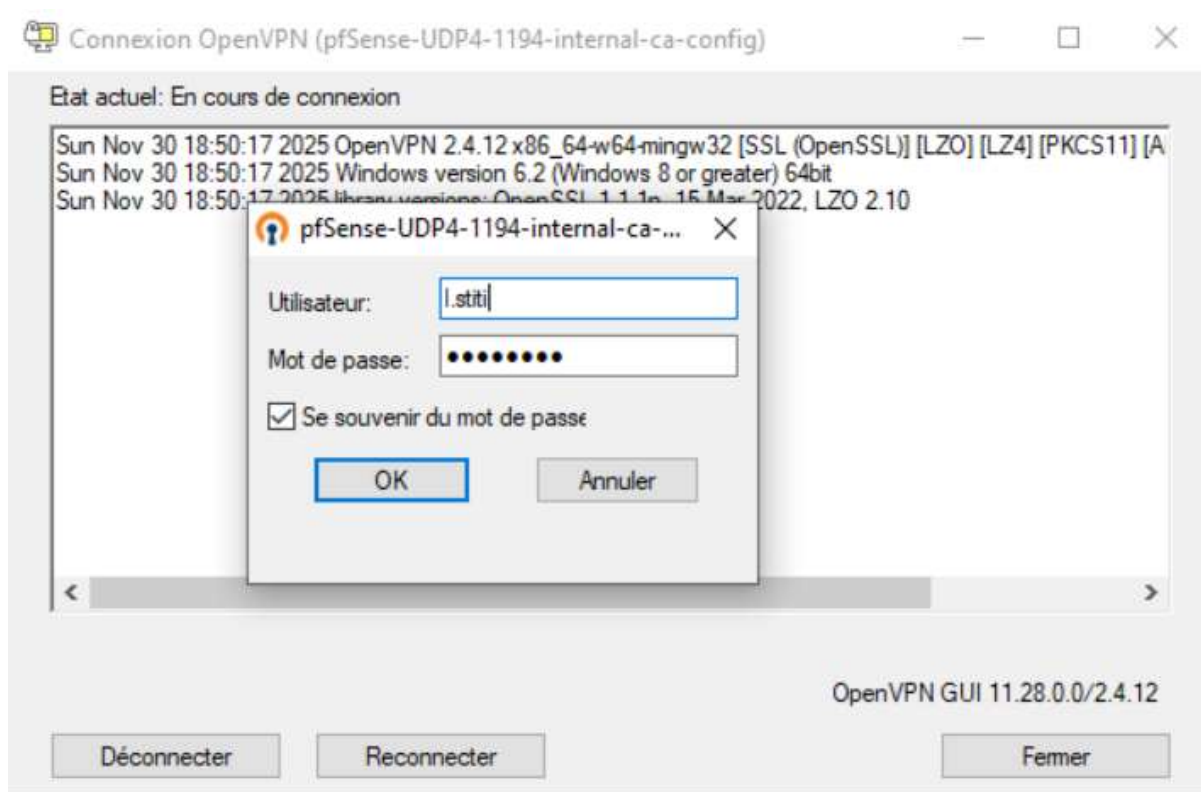
1. Lancer le client OpenVPN.
2. Sélectionner le profil de connexion.
3. S'authentifier avec son **login / mot de passe AD**.
4. Le client établit alors le tunnel SSL/TLS avec pfSense, en présentant son **certificat client**.

Une fois connecté, l'utilisateur :

- reçoit une adresse IP dans le réseau 10.10.10.0/24 (sous-réseau /30 dédié) ;
- utilise le **DNS interne** (DC-01) pour résoudre les ressources du domaine adraf.lan ;
- accède au **serveur de fichiers** comme s'il était sur le LAN (lecteurs réseaux, partages SMB).

4.4.3. Tests fonctionnels

- **Connexion VPN :**



Etat actuel: Connecté

```
Sun Nov 30 21:01:52 2025 OpenVPN 2.4.12 x86_64-w64-mingw32 [SSL (OpenSSL)] [LZO] [LZ4] [PKCS11] [AEAD] built on
Sun Nov 30 21:01:52 2025 Windows version 6.2 (Windows 8 or greater) 64bit
Sun Nov 30 21:01:52 2025 library versions: OpenSSL 1.1.1n 15 Mar 2022, LZO 2.10
Sun Nov 30 21:01:56 2025 TCP/UDP: Preserving recently used remote address: [AF_INET]172.16.9.230:1194
Sun Nov 30 21:01:56 2025 UDP link local: (not bound)
Sun Nov 30 21:01:56 2025 UDP link remote: [AF_INET]172.16.9.230:1194
Sun Nov 30 21:01:56 2025 [internal-ca] Peer Connection Initiated with [AF_INET]172.16.9.230:1194
Sun Nov 30 21:01:57 2025 open_tun
Sun Nov 30 21:01:57 2025 TAP-WIN32 device [Connexion au réseau local] opened: \\.\Global\{49C0552D-6543-455F-A5
Sun Nov 30 21:01:57 2025 Notified TAP-Windows driver to set a DHCP IP/netmask of 10.10.10.6/255.255.255.252 on interf
Sun Nov 30 21:01:57 2025 Successful ARP Flush on interface [5] {49C0552D-6543-455F-A506-BAE77C39360A}
Sun Nov 30 21:02:03 2025 Initialization Sequence Completed
```

Adresse IP assignée: 10.10.10.6

Bytes in: 3720 (3.6 KiB) out 8746 (8.5 KiB)

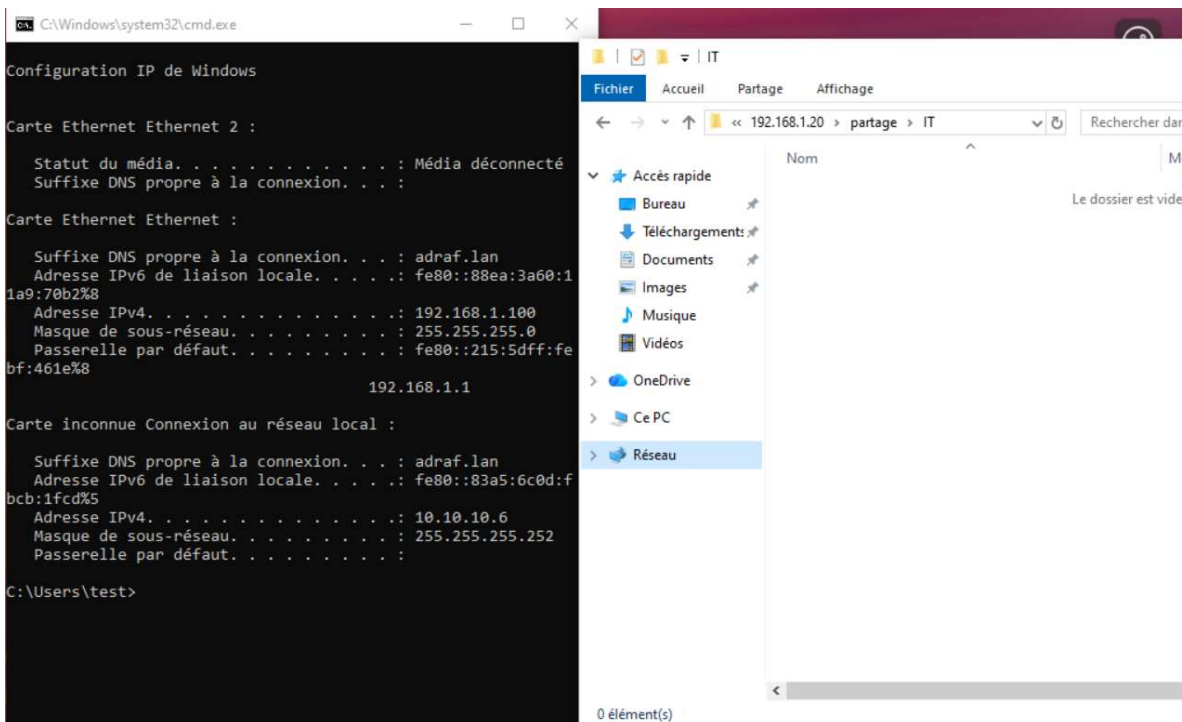
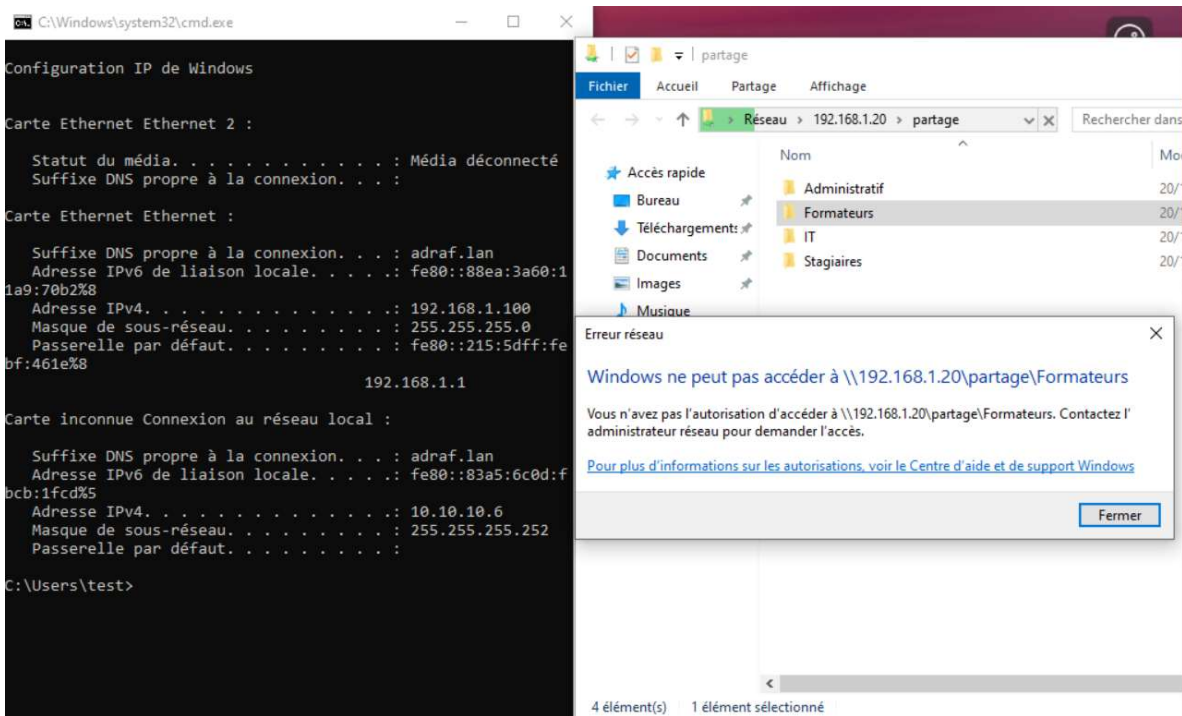
OpenVPN GUI 11.28.0.0/2.4.12

Déconnecter

Reconnecter

Fermer

- Accès aux **partages réseau** (Accès aux partages réseau, respect des droits NTFS)



4.5. Durcissement et mesures de sécurité appliquées

4.5.1. Durcissement de pfSense et d'OpenVPN

Plusieurs mesures de durcissement ont été appliquées :

- **Mises à jour** : pfSense est maintenu à jour (version stable récente), de même que les paquets OpenVPN.
- **Accès d'administration** :
 - interface d'admin accessible uniquement depuis le **VLAN admin** du LAN ;
 - désactivation de l'accès HTTP, utilisation systématique de **HTTPS** pour l'interface ;
 - filtrage par adresse IP + authentification forte (mot de passe robuste, comptes limités).
- **Services inutiles** : désactivation de tous les services non nécessaires (portail captif, DHCP si non utilisé, etc.).
- **OpenVPN** :
 - algorithmes de chiffrement conformes aux recommandations actuelles (AES, SHA-2, PFS) ;
 - interdiction des versions obsolètes de TLS ;
 - isolation client-à-client activée.

4.5.2. Mesures recommandées (non encore mises en place)

Certaines mesures sont identifiées comme **axes d'amélioration** pour une future évolution :

- **Mise en place d'un MFA** (TOTP, application mobile, clé FIDO2...) pour renforcer l'authentification au VPN.
- **Haute disponibilité** de pfSense (cluster CARP) afin d'éviter le point unique de défaillance.
- **Segmentation plus fine** du LAN (VLAN serveurs / postes / admin) pour limiter encore les mouvements latéraux en cas de compromission.
- **Supervision avancée** des logs (SIEM, corrélation d'événements) pour détecter les comportements anormaux (tentatives multiples, connexions depuis des pays inhabituels, etc.).

4.6. Journalisation, supervision et exploitation

4.6.1. Journalisation des connexions VPN

pfSense consigne :

- les **connexions et déconnexions** VPN (heure, utilisateur, adresse IP source, IP VPN attribuée) ;
- les **tentatives échouées** d'authentification ;
- les **erreurs** de négociation TLS.

Ces logs sont essentiels pour :

- retracer les actions en cas d'incident de sécurité ;
- vérifier le respect des comptes autorisés (groupe AD VPN) ;
- détecter d'éventuels **brute force** ou essais répétés sur des comptes.

4.6.2. Exploitation des logs

Dans un premier temps, les journaux sont exploitables directement via l'interface pfSense.

En production, il serait souhaitable :

- d'exporter ces logs vers un **serveur syslog central** ;
- voire de les intégrer dans une solution de type **SIEM** open source (Graylog, ELK, Wazuh...) pour des analyses plus fines (corrélation, tableaux de bord, alertes).

4.6.3. Exploitation et procédures d'exploitation

Le **service IT** est responsable :

- de la création des comptes AD et de leur ajout dans les groupes VPN ;
- de la génération et de la remise des certificats/profils OpenVPN aux utilisateurs ;
- de la **revue régulière** des comptes autorisés ;
- de la **révocation** des certificats en cas de départ ou de suspicion de compromission.

Des procédures simples peuvent être documentées :

- "Créer un nouvel utilisateur VPN" ;
- "Révoquer un accès VPN" ;
- "Analyser un incident lié au VPN (compte compromis, activité suspecte)".

Section 5 – Bilan et conclusion

5.1. Bilan technique

Le projet visait à permettre aux collaborateurs de l'entreprise d'accéder à distance au **serveur de fichiers interne** comme s'ils étaient présents sur site, tout en respectant les exigences de sécurité (ANSSI), de maîtrise des risques (MITRE ATT&CK) et de protection des données (RGPD).

Sur le plan **technique**, les objectifs sont atteints :

- Mise en place d'un pare-feu pfSense jouant le rôle de passerelle Internet et de concentrateur VPN.
- Déploiement d'un VPN SSL/TLS OpenVPN en mode remote access :
 - Tunnel chiffré TLS conforme aux bonnes pratiques (suites cryptographiques modernes, PFS), en cohérence avec les recommandations de l'ANSSI sur TLS.
- Création d'un **réseau dédié aux clients VPN** (10.10.10.0/24), avec :
 - Attribution d'un réseau /30 par utilisateur,
 - Isolation client–client,
 - Filtrage strict vers le LAN.
- **Segmentation logique** des flux :
 - Depuis le VPN, seuls les serveurs AD/DNS (192.168.1.19) et serveur de fichiers (192.168.1.20) sont accessibles ;
 - Aucun accès direct aux autres postes du LAN n'est autorisé.
- Choix d'un **mode full tunnel** : tout le trafic Internet des postes distants passe par le VPN et sort via pfSense, ce qui permet d'appliquer les politiques de filtrage de l'entreprise et de maîtriser les flux, en ligne avec le guide ANSSI sur le nomadisme numérique (maîtrise des tunnels VPN et des flux réseau du poste nomade).
- Intégration du VPN avec l'**Active Directory** :
 - Authentification via LDAPS sur le contrôleur de domaine DC-01 ;
 - Restriction de l'accès VPN à des groupes AD dédiés ;
 - Réutilisation des droits NTFS existantes pour contrôler l'accès aux partages.
- Activation de la **journalisation** des connexions VPN :
 - connexions/déconnexions,
 - tentatives échouées,
 - erreurs de négociation TLS.

Cette architecture répond aux principaux risques identifiés à partir de **MITRE ATT&CK** :

- Technique **T1133 – External Remote Services** : les accès à distance passent par un point d'entrée unique (pfSense/OpenVPN) durci, filtré et supervisé, au lieu de services dispersés (RDP ouvert, SMB, etc.).
- Technique **T1078 – Valid Accounts** :
 - Utilisation de l'AD, des politiques de mot de passe, du verrouillage de comptes et des certificats limite l'exploitation de comptes compromis ;
 - Les journaux de connexion aident à détecter une utilisation suspecte de comptes légitimes.

Du point de vue RGPD, le projet améliore la situation :

- Les données personnelles présentes sur le serveur de fichiers sont protégées pendant le transport par un chiffrement fort ;
- L'accès distant repose sur des droits existants (groupes AD, ACL NTFS), ce qui respecte le principe de minimisation des accès ;
- La journalisation des connexions VPN contribue au principe d'intégrité/confidentialité (article 5 & 32 du RGPD) et à la capacité de démontrer les mesures de sécurité mises en œuvre.

5.4. Axes d'amélioration et perspectives

Même si la solution déployée est fonctionnelle et sécurisée, plusieurs pistes d'amélioration peuvent être envisagées pour tendre encore davantage vers l'"état de l'art" décrit par l'ANSSI et par les référentiels de menaces comme MITRE ATT&CK.

5.4.1. Renforcement de l'authentification

- Mettre en place une authentification multi facteur (MFA) pour l'accès VPN :
 - Application d'authentification (TOTP), clé FIDO2, certificat qualifié, etc.
 - Le MFA est explicitement recommandé comme mesure de mitigation pour la technique T1078 – Valid Accounts, afin de limiter l'impact d'un vol de mot de passe.
- Étudier l'usage d'un portail d'authentification centralisé ou d'un fournisseur d'identité pour fédérer les mécanismes de SSO et de MFA.

5.4.2. Haute disponibilité et résilience

- Déployer un cluster de pare-feux pfSense (CARP) pour supprimer le point unique de défaillance actuel :
 - Deux VM pfSense, sur deux hôtes Hyper-V distincts ;
 - Configuration de la synchronisation de la configuration et des états de sessions.
- Prévoir, si le contexte le justifie, un second lien Internet (multi-opérateur) afin de garantir la continuité de service du VPN en cas de panne sur le lien principal.

5.4.3. Segmentation interne plus fine

- Introduire des VLAN distincts (serveurs, postes utilisateurs, administration) et adapter les règles de filtrage entre ces VLAN
- Limiter encore davantage les communications possibles depuis le réseau VPN, conformément aux recommandations de segmentation et de “défense en profondeur” mises en avant par l’ANSSI et par les bonnes pratiques de sécurité réseau.

Cela permettrait de réduire encore les possibilités de mouvement latéral en cas de compromission d’un poste nomade (techniques de type T1021 – Remote Services, liées à T1133).

5.4.4. Supervision avancée et détection d’incidents

- Centraliser les journaux pfSense / OpenVPN sur un serveur syslog ou une solution SIEM open source (ELK, Graylog, Wazuh...)
- Mettre en place :
 - des alertes en cas de trop nombreuses tentatives de connexion échouées ;
 - des alertes sur des connexions depuis des pays inhabituels ou à des horaires atypiques ;
 - des tableaux de bord illustrant les connexions VPN dans le temps.
- S’inspirer des scénarios de détection décrits pour la technique T1133 – External Remote Services afin d’identifier un usage anormal du VPN.

5.4.5. Évolutions possibles de la technologie VPN

À moyen terme, plusieurs évolutions techniques pourraient être étudiées :

- **IPsec IKEv2 nomade** :
 - pour se rapprocher encore davantage des recommandations ANSSI, qui considèrent IPsec à l’état de l’art pour la protection des flux réseau, tout en maintenant un VPN TLS correctement durci pour certains cas d’usage.
- **WireGuard** :
 - pour des scénarios nécessitant des performances très élevées et une configuration minimale ;
 - à évaluer toutefois au regard de l’intégration AD, de la gestion des clés et de la supervision.

5.4.6. Renforcement du poste nomade et conformité RGPD

- Durcir la configuration des **postes clients** (EDR, chiffrement disque, restrictions administrateur local), conformément aux recommandations ANSSI sur le nomadisme.
- Documenter clairement :
 - la **durée de conservation** des journaux VPN ;
 - les **mesures d’information** des utilisateurs sur cette journalisation ;
 - les modalités d’exercice de leurs droits (accès, effacement, opposition) au sens du RGPD.

Références normatives et guides

- ANSSI – Recommandations sur le nomadisme numérique (VPN IPsec/TLS, durcissement des postes nomades, maîtrise des flux).
- ANSSI – Recommandations de sécurité relatives à TLS (versions recommandées, suites cryptographiques).
- Guides ANSSI sur IPsec et la protection des flux réseau.
- RGPD – Règlement (UE) 2016/679 (texte officiel et synthèse CNIL / UE).

Documentation technique

- Documentation officielle pfSense – OpenVPN Remote Access (Netgate).
- Documentation et HOWTO OpenVPN Community (configuration, sécurité, dépannage).

Table des abréviations

ACL

Access Control List (Liste de contrôle d'accès)

AD

Active Directory

AES

Advanced Encryption Standard

ANSSI

Agence Nationale de la Sécurité des Systèmes d'Information

CARP

Common Address Redundancy Protocol

CNIL

Commission Nationale de l'Informatique et des Libertés

DHCP

Dynamic Host Configuration Protocol

DNS

Domain Name System

DSI

Direction des Systèmes d'Information

EDR

Endpoint Detection and Response

FIDO2

Fast Identity Online 2 (Standard d'authentification)

GPO

Group Policy Object (Stratégie de groupe)

HA

High Availability (Haute Disponibilité)

HTTPS

Hypertext Transfer Protocol Secure

IKEv2

Internet Key Exchange version 2

IP

Internet Protocol

IPsec

Internet Protocol Security

LAN

Local Area Network (Réseau local)

LDAP / LDAPS

Lightweight Directory Access Protocol (Secure)

MFA

Multi-Factor Authentication (Authentification multifacteur)

MITRE ATT&CK

MITRE Adversarial Tactics, Techniques, and Common Knowledge

NAT

Network Address Translation

NTFS

New Technology File System

OS

Operating System (Système d'exploitation)

PFS

Perfect Forward Secrecy

PKI

Public Key Infrastructure (Infrastructure à clés publiques)

RDP

Remote Desktop Protocol

RGPD

Règlement Général sur la Protection des Données

SD-WAN

Software-Defined Wide Area Network

SHA

Secure Hash Algorithm

SI

Système d'Information

SIEM

Security Information and Event Management

SMB

Server Message Block

SPOF

Single Point Of Failure (Point unique de défaillance)

SSL

Secure Sockets Layer

TLS

Transport Layer Security

TOTP

Time-based One-Time Password

VLAN

Virtual Local Area Network

VM

Virtual Machine (Machine Virtuelle)

VPN

Virtual Private Network (Réseau Privé Virtuel)

WAN

Wide Area Network (Réseau étendu / Internet)